

SAML 2.0 Configuration Guide

Last updated by | Haroun Ahmady | Apr 14, 2026 at 9:05 AM PDT

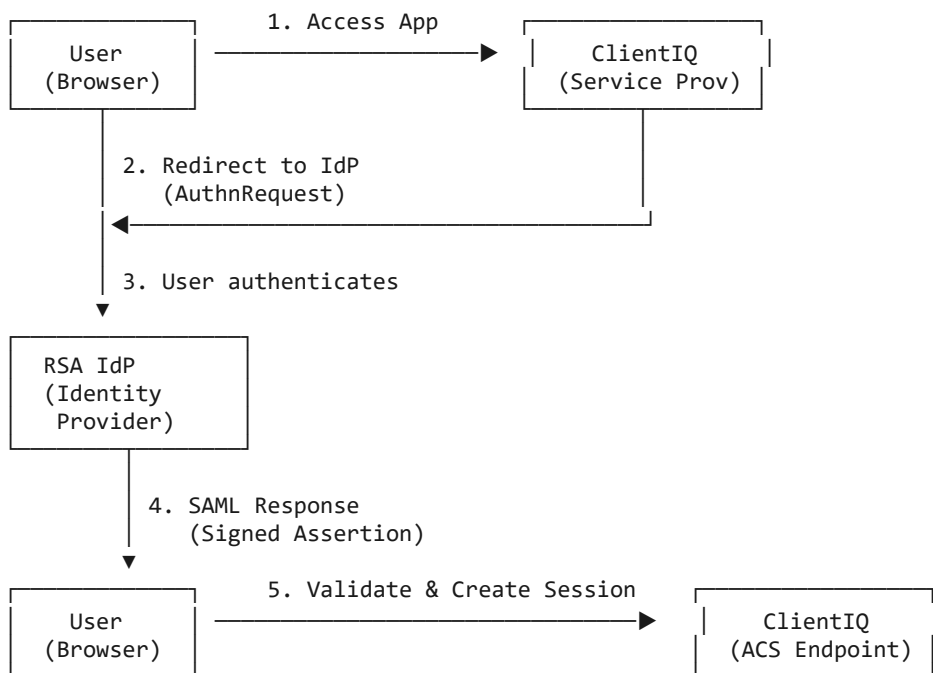
SAML 2.0 Configuration Guide

Overview

ClientIQ uses SAML 2.0 for enterprise single sign-on (SSO) authentication. This guide covers:

- RSA Identity Provider (IdP) integration
- Service Provider (SP) configuration
- Attribute mapping
- Role synchronization
- Troubleshooting authentication issues

Architecture



Prerequisites

Before configuring SAML:

1. RSA IdP administrator access or coordination
2. SSL certificate installed (Document 03)
3. Application accessible at public URL
4. Understanding of your IdP attribute names

Step 1: Gather IdP Information

Request the following from your IdP administrator:

Item	Description	Example
IdP Entity ID	Unique identifier for IdP	<code>https://idp.yourbank.com/saml</code>
SSO URL	Single Sign-On endpoint	<code>https://idp.yourbank.com/saml/sso</code>
SLO URL	Single Logout endpoint	<code>https://idp.yourbank.com/saml/logout</code>
IdP Certificate	X.509 certificate for signature verification	Base64-encoded certificate
NameID Format	User identifier format	<code>emailAddress</code> OR <code>persistent</code>

Step 2: Configure Service Provider

Environment Variables

Add the following to your `.env` file:

```
# =====
# SAML Configuration
# =====

# IdP SSO Endpoint - URL where authentication requests are sent
SAML_ENTRYPOINT=https://idp.yourbank.com/saml/sso

# Service Provider Entity ID - Unique identifier for ClientIQ
SAML_ISSUER=ClientIQ-Production

# Assertion Consumer Service URL - Where IdP sends SAML responses
SAML_CALLBACK_URL=https://clientiq.yourbank.com/api/auth/saml/acs

# IdP Logout URL (optional, for SP-initiated logout)
SAML_LOGOUT_URL=https://idp.yourbank.com/saml/logout

# Logout callback URL (optional)
SAML_LOGOUT_CALLBACK_URL=https://clientiq.yourbank.com/api/auth/saml/logout/callback

# IdP Certificate - For verifying SAML assertion signatures
# Copy the certificate content WITHOUT the BEGIN/END lines
# Must be a single line (no line breaks)
SAML_CERT=MIIDxTCCAq2gAwIBAgIJAKPv...base64content...==

# Private key for assertion decryption (optional, if IdP encrypts assertions)
# SAML_DECRYPT_KEY=MIIEvQIBADANBgkqhkiG9w0BAQE...
```

Certificate Handling

The IdP certificate should be provided as a single-line base64 string:

```
# Convert multi-line certificate to single line
$cert = Get-Content "C:\ClientIQ\certs\idp-cert.pem" -Raw
$certOneLine = $cert -replace "-----BEGIN CERTIFICATE-----", "" `
    -replace "-----END CERTIFICATE-----", "" `
    -replace "`r`n", "" `
    -replace "`n", ""
Write-Host "SAML_CERT=$certOneLine"
```

Step 3: Configure IdP (RSA)

Provide the following to your IdP administrator:

Service Provider Metadata

The application exposes SP metadata at:

<https://clientiq.yourbank.com/api/auth/saml/metadata>

Or provide manually:

Setting	Value
Entity ID / Issuer	ClientIQ-Production
ACS URL	https://clientiq.yourbank.com/api/auth/saml/acs
ACS Binding	HTTP-POST
NameID Format	urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress
Sign AuthnRequest	Yes (SHA-256)
Want Assertions Signed	Yes

Required Attributes

Configure the IdP to release these attributes in SAML assertions:

Attribute Name	SAML URI	Required	Description
Employee ID	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeeid	Yes	Unique employee identifier (numeric)
Employee Number	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeenumber	Yes	Employee badge/number
First Name	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/givenname	Yes	User's first name
Last Name	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/surname	Yes	User's last name
Email	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress	Yes	User's email address
Department	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/department	No	User's department
Role	http://schemas.xmlsoap.org/ws/2005/05/identity/claims/role	No	User's role (auto-assigned)

Example SAML Assertion

```
<saml:Assertion xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion">
  <saml:Subject>
    <saml:NameID Format="urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress">
      john.doe@yourbank.com
    </saml:NameID>
  </saml:Subject>
  <saml:AttributeStatement>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeeid">
      <saml:AttributeValue>12345</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeeid">
      <saml:AttributeValue>EMP001234</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/givenname">
      <saml:AttributeValue>John</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/surname">
      <saml:AttributeValue>Doe</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress">
      <saml:AttributeValue>john.doe@yourbank.com</saml:AttributeValue>
    </saml:Attribute>
    <saml:Attribute Name="http://schemas.xmlsoap.org/ws/2005/05/identity/claims/role">
      <saml:AttributeValue>Relationship_Manager</saml:AttributeValue>
    </saml:Attribute>
  </saml:AttributeStatement>
</saml:Assertion>
```

Step 4: Role Mapping

ClientIQ supports automatic role assignment based on SAML role attributes.

SAML Role Mapping Table

The `saml_role_mapping` table maps IdP roles to application roles:

saml_role_key	role_id	sync_mode	Description
System_Admin	1	enforced	Always syncs role
Relationship_Manager	3	initial	Only on first login
Teller	5	initial	Only on first login

Sync Modes

- `initial` : Role assigned only on user's first login. Manual changes are preserved.
- `enforced` : Role synced on every login. IdP is the source of truth.

Configure Role Mappings

Use SQL to add mappings:

```

-- Map IdP role "System_Admin" to ClientIQ "System Administrator" role
INSERT INTO saml_role_mapping (saml_role_key, role_id, sync_mode, description, is_active)
VALUES ('System_Admin', 1, 'enforced', 'System administrators from AD', 1);

-- Map IdP role "RM_Commercial" to "Commercial RM" role
INSERT INTO saml_role_mapping (saml_role_key, role_id, sync_mode, description, is_active)
VALUES ('RM_Commercial', 3, 'initial', 'Commercial relationship managers', 1);

-- View current mappings
SELECT srm.saml_role_key, r.role_name, srm.sync_mode, srm.is_active
FROM saml_role_mapping srm
JOIN role r ON r.role_id = srm.role_id;

```

Step 5: Custom Attribute Mapping

If your IdP uses different attribute names, update the attribute map in the application:

Current Attribute Map

Located in `server/auth/samlStrategy.ts`:

```

const ATTRIBUTE_MAP = {
  employeeId: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeeid',
  employeeNumber: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/employeenumber',
  firstName: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/givenname',
  lastName: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/surname',
  email: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/emailaddress',
  department: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/department',
  role: 'http://schemas.xmlsoap.org/ws/2005/05/identity/claims/role'
};

```

Override via Environment Variables

You can customize attribute names without code changes:

```

# Custom attribute URIs (if your IdP uses different names)
SAML_ATTR_EMPLOYEE_ID=urn:oid:1.2.840.113556.1.4.1
SAML_ATTR_EMPLOYEE_NUMBER=urn:oid:1.2.840.113556.1.4.2
SAML_ATTR_FIRST_NAME=urn:oid:2.5.4.42
SAML_ATTR_LAST_NAME=urn:oid:2.5.4.4
SAML_ATTR_EMAIL=urn:oid:0.9.2342.19200300.100.1.3
SAML_ATTR_DEPARTMENT=urn:oid:2.5.4.11
SAML_ATTR_ROLE=urn:oid:1.2.840.113556.1.4.3

```

Step 6: Test SAML Authentication

Generate SP Metadata

```

# Fetch and save SP metadata
Invoke-WebRequest -Uri "https://clientiq.yourbank.com/api/auth/saml/metadata" `
  -OutFile "C:\ClientIQ\certs\sp-metadata.xml"

# Review metadata
Get-Content "C:\ClientIQ\certs\sp-metadata.xml"

```

Test Login Flow

1. Navigate to `https://clientiq.yourbank.com`
2. Click "Sign In with SSO" or access protected resource
3. Should redirect to IdP login page
4. Authenticate with IdP credentials
5. Should redirect back to ClientIQ and be logged in

Check Logs

```
# View SAML-related logs
Select-String -Path "C:\ClientIQ\logs\stdout.log" -Pattern "\[SAML\]" -Context 2,5

# Check for authentication errors
Select-String -Path "C:\ClientIQ\logs\stderr.log" -Pattern "SAML|assertion|signature" -Context 2,5
```

Debug Mode

Enable debug logging temporarily:

```
# Add to .env for troubleshooting
DEBUG=passport:*,passport-saml:*
```

Security Considerations

Signature Verification

ClientIQ requires signed assertions:

```
signatureAlgorithm: 'sha256',
digestAlgorithm: 'sha256',
wantAssertionsSigned: true,
```

Audience Restriction

The application validates the audience in SAML assertions matches the configured issuer.

Clock Skew

A 5-minute clock skew tolerance is configured:

```
acceptedClockSkewMs: 5 * 60 * 1000, // 5 minutes
```

Ensure server time is synchronized with NTP.

Session Security

- Sessions are regenerated after successful authentication

- Session cookies are HTTP-only and secure
- Session timeout configurable via `SESSION_TIMEOUT` environment variable

Troubleshooting

"Invalid Signature" Error

1. Verify IdP certificate is correct and complete
2. Check certificate hasn't expired
3. Ensure no whitespace/newlines in `SAML_CERT` value
4. Verify IdP is signing with expected algorithm (SHA-256)

"Missing Required Attributes" Error

1. Check IdP is releasing all required attributes
2. Verify attribute URIs match configuration
3. Review SAML assertion in IdP logs
4. Enable debug logging to see received attributes

"Audience Mismatch" Error

1. Verify `SAML_ISSUER` matches what's configured in IdP
2. Check for typos in Entity ID

User Not Created/Updated

1. Check `employeeid` is numeric and valid
2. Verify database connection is working
3. Review application logs for database errors

Redirect Loop

1. Check ACS URL is correctly configured in IdP
2. Verify Nginx is passing correct headers
3. Ensure cookies are being set (check browser dev tools)

Logout Not Working

1. Verify `SAML_LOGOUT_URL` is configured
2. Check IdP supports SP-initiated logout
3. Session might be cleared but IdP session remains active

SAML Endpoints Reference

Endpoint	URL	Method	Description
Login	/api/auth/saml/login	GET	Initiates SSO
ACS	/api/auth/saml/acs	POST	Receives SAML response
Metadata	/api/auth/saml/metadata	GET	SP metadata
Logout	/api/auth/saml/logout	GET	Initiates logout
Session	/api/auth/session	GET	Check current session

Next Steps

1. [Review Database Design](#)
2. [Configure SQL Server](#)
3. [Environment Variables Reference](#)